API REST PARA EL MANEJO DE UN SISTEMA BIBLIOTECARIO

Datos del proyecto	Información
Módulo / asignatura	Utilizancion de Frameworks para el Desarrollo de Software
Docente	Oscar Alfredo Cruz Rovira
Integrantes	1. _____ 2. _____ 3. _____
Fecha de entrega	Semana 16 del Ciclo II 2026

1. Definición del proyecto

Desarrollar una API REST que permita administrar las operaciones principales de una biblioteca. La solución deberá gestionar usuarios, catálogo bibliográfico, ejemplares y préstamos, e incorporar autenticación mediante credenciales y autorización mediante tokens. El sistema debe demostrar controles de acceso, validación de datos, persistencia y respuestas HTTP coherentes.

2. Situación problemática

Una biblioteca requiere centralizar la gestión de sus recursos y evitar procesos manuales que dificultan saber qué libros existen, cuáles están disponibles, quién tiene un ejemplar prestado y cuándo debe devolverlo. Además, no todos los usuarios deben poder realizar las mismas operaciones. Por ello se necesita una API segura que sirva como base para futuras aplicaciones web, móviles o de escritorio.

3. Competencia general del proyecto

Construir una API REST segura y mantenible para resolver un problema de gestión bibliotecaria, aplicando modelado de datos, operaciones CRUD, reglas de negocio, autenticación, autorización por token, validación, manejo de errores y documentación técnica.

4. Resultados de aprendizaje esperados

- Diseña un modelo de datos coherente con las necesidades del sistema bibliotecario.
- Implementa recursos REST utilizando métodos HTTP, códigos de estado y estructuras de respuesta apropiadas.
- Aplica autenticación de usuarios y autorización mediante token, evitando exponer credenciales o información sensible.
- Implementa reglas de negocio para préstamos y devoluciones, manteniendo la integridad de los datos.
- Documenta, prueba y demuestra el funcionamiento de la API de manera reproducible.

5. Alcance funcional mínimo

Módulos obligatorios

Módulo	Capacidad mínima esperada
Usuarios y roles	Registro/administración de usuarios; roles como administrador y bibliotecario/usuario.
Autenticación	Login con credenciales válidas y emisión de token.
Catálogo	CRUD de libros; asociación con autor y categoría.
Préstamos	Creación de préstamo, consulta de préstamos activos e historial.
Devoluciones	Registro de devolución y actualización de disponibilidad.

Entidades sugeridas

El equipo puede adaptar el modelo siempre que justifique sus decisiones. Como referencia, el sistema debería contemplar:

- Usuario
- Rol
- Libro
- Autor
- Categoría
- Préstamo

Importante: no es obligatorio usar exactamente estos nombres ni esta cantidad de tablas. La evaluación considerará la coherencia del modelo y la cobertura de los requisitos.

6. Reglas de negocio mínimas

1. No se puede prestar un libro que ya se encuentre prestado o no disponible.
2. Un préstamo debe identificar como mínimo al usuario, libro, fecha de préstamo y estado.
3. Al registrar una devolución, el libro debe volver a estar disponible.
4. Las operaciones administrativas deben estar restringidas según el rol o permiso definido.
5. Las credenciales incorrectas no deben revelar si el usuario existe ni exponer información sensible.
6. Los datos de entrada deben validarse antes de ser procesados o almacenados.
7. Las eliminaciones que comprometan integridad referencial deben impedirse o manejarse mediante una estrategia justificada.

7. Requisitos de seguridad

- Implementar un endpoint de login que reciba credenciales y entregue un token de acceso cuando sean correctas.
- Almacenar las contraseñas usando un algoritmo de hash de contraseñas apropiado; nunca guardar contraseñas en texto plano.
- El token debe tener tiempo de expiración y debe ser validado en las rutas protegidas.
- El servidor debe identificar al usuario autenticado a partir del token antes de autorizar acciones protegidas.
- Aplicar control de acceso por roles o permisos en las operaciones que lo requieran.

8. Casos de prueba obligatorios

#	Prueba	Evidencia esperada
1	Login válido	Se obtiene token y datos mínimos necesarios para autenticación.
2	Login inválido	Se rechaza el acceso sin exponer credenciales ni información sensible.
3	Ruta protegida sin token	La API deniega el acceso con respuesta HTTP apropiada.
4	Token inválido o expirado	La API rechaza la solicitud.
5	Acción sin permiso	Un usuario autenticado sin privilegios no puede ejecutar la operación.
6	CRUD de libro	Crear, consultar, actualizar y eliminar/gestionar restricciones correctamente.
7	Préstamo válido	El préstamo se registra y el ejemplar deja de estar disponible.
8	Préstamo inválido	Se impide prestar un ejemplar no disponible.
9	Devolución	Se registra y el ejemplar vuelve a estar disponible.
10	Datos inválidos	La API rechaza entradas que incumplen las reglas de validación.

9. Criterios para la demostración

Durante la demostración el equipo deberá ejecutar la API y probar, como mínimo, los siguientes flujos sin modificar manualmente datos directamente en la base para simular resultados:

- autenticación y obtención del token
- consumo de una ruta protegida
- operación permitida y operación rechazada por permisos
- registro y consulta de libros
- préstamo de un ejemplar disponible
- intento de préstamo de un ejemplar no disponible
- devolución y actualización de disponibilidad

Sistema de evaluación.

Objetivo: Evaluar las competencias técnicas del estudiante para desarrollar una API REST funcional, segura y documentada para un sistema bibliotecario, aplicando autenticación, seguridad por token, gestión de datos, reglas de negocio y buenas prácticas de desarrollo.

Integrantes:

Competencia	%	Evidencia / criterio	Nivel 4 ,100%	Nivel 3 , 80%	Nivel 2 , 60%	Nivel 1, 40%	
C1. Modela la solución y los datos	20 %	Modelo de entidades, relaciones, restricciones e integridad; correspondencia entre datos y problema.	Modelo coherente, normalizado según necesidad, restricciones claras y relaciones justificadas.	Modelo funcional con pequeñas inconsistencias o decisiones poco justificadas.	Modelo parcial; faltan relaciones/reglas importantes o existen inconsistencias que afectan operaciones.	Modelo ausente, incoherente o incapaz de soportar los flujos obligatorios.	
C2. Construye servicios REST funcionales	25 %	Endpoints, métodos HTTP, CRUD, validaciones, códigos de estado, manejo de errores y reglas de negocio.	Todos los flujos obligatorios funcionan; diseño REST consistente; validaciones y errores correctos.	La mayoría de flujos funciona; existen errores menores de diseño, validación o códigos HTTP.	Solo parte de los flujos funciona; hay lógica mezclada, errores frecuentes o reglas de negocio incompletas.	Los endpoints principales no funcionan o no permiten demostrar los casos de uso exigidos.	
C3. Implementa autenticación y seguridad por token	25 %	Login, hash de contraseñas, emisión/validación/expiración del token, rutas protegidas y autorización por roles/permisos.	Login seguro; contraseñas protegidas; token válido y con expiración; autorización efectiva; secretos fuera del código; no se exponen datos sensibles.	Seguridad funcional con deficiencias menores que no permiten eludir controles principales.	Autenticación parcial; controles incompletos, permisos inconsistentes o manejo débil de secretos/tokens.	Contraseñas en texto plano, rutas críticas sin protección, token no validado o controles fácilmente eludibles.	
C4. Garantiza calidad técnica, pruebas y documentación	20 %	Organización del código, configuración, reproducibilidad, documentación, pruebas y manejo consistente de respuestas.	Proyecto organizado y reproducible; documentación completa; pruebas cubren casos positivos y negativos; errores controlados.	Proyecto ejecutable y documentado; pruebas suficientes, aunque con cobertura o claridad mejorable.	Ejecución dependiente de pasos no documentados; pruebas escasas o documentación incompleta.	No es reproducible, carece de documentación útil o no existen evidencias verificables de pruebas.	
C5. Demuestra y argumenta la solución	10 %	Demostración técnica, explicación de decisiones, interpretación de resultados y capacidad de corregir/diagnosticar.	Demuestra todos los flujos, explica decisiones técnicas y responde con evidencia del sistema.	Demuestra los flujos principales y explica adecuadamente la mayoría de decisiones.	Demostración parcial; dificultad para justificar decisiones o identificar causas de fallos.	No logra demostrar el funcionamiento o no puede explicar la relación entre código, datos y resultados.	
Total:							

Observaciones del docente

_____

_____

_____